The broker terminates TLS and re-originates every message, so an arriving command carries no evidence of who published it. Broker credentials decide admission. Only the command key decides authority.

## AUTH_COMMANDS = 1 — application-layer authentication required

Acted on only if the HMAC-SHA256 tag verifies under SECRET_CMD_KEY and the counter exceeds the value in NVS.

| Publisher | Broker | Device check | Outcome |
|---|---|---|---|
| **Operator** credential + key | **admits** | tag verifies, counter advances | **DISARM executes** |
| **Adversary** credential, no key | **admits** | tag fails: cmd_badmac | **rejected; alarm fires 300/300** |
| **Adversary** controller cred + key | **admits** | tag verifies, counter advances | **DISARM executes; alarm fires 50/300** |

Row 3 is a compromised controller host: a credential the ACL must permit plus the key. Neither layer refuses it.

## ALLOW_REMOTE_DISARM = 1 without AUTH_COMMANDS — the guard this work removed

The guard treated TLS plus a broker login as sufficient: the HMAC test is skipped, so any admitted DISARM is acted on.

| Publisher | Broker | Device check | Outcome |
|---|---|---|---|
| **Operator** credential, no key | **admits** | no check: ALLOW_REMOTE_DISARM | **DISARM executes** |
| **Adversary** credential, no key | **admits** | no check: ALLOW_REMOTE_DISARM | **DISARM executes; alarm fires 50/300** |

## Control, identical in both builds

| | | | |
|---|---|---|---|
| **Adversary** no credential | **refuses** | never reached | **connection refused; alarm fires 300/300** |

Outcome colour is the only colour that carries meaning: green, the alarm still protects the house; red, an unauthorised DISARM succeeded. Every outcome also states its measured count.